SIBER GÜVENLIK MÜHENDISLIĞI EĞITIMI - 2026

201 AD OPERASYONU: "Domain Dominance"

24 NİSAN 2026

Metehan Eroğlu

📝 FAZ 1: Mimari ve Temeller (Research & Logic)

🏛 Cephe 1: Windows Active Directory Basics

- **Hedef:** TryHackMe: Windows AD Basics
- **Görev:** Bu odayı baştan sona tamamlayarak Active Directory'nin omurgasını oluşturan temel bileşenleri ve hiyerarşiyi kavrayın.
- **Beklenti & Raporlama:** Odada öğrendiklerinize dayanarak, aşağıdaki 3 kritik kavramı teknik bir dille ve kendi cümlelerinizle açıklayın:

1. Domain Controller (DC): "Krallığın Merkezi"

- Domain Controller nedir? Kurumsal bir ağda binlerce bilgisayar varken, kimlik doğrulama ve yetkilendirme işlemleri için neden böyle merkezi bir sunucuya ihtiyaç duyarız?

➢ Domain Controller bir şirketteki tüm cihazları, Kullanıcıları, Yazıcıları, Serverları Active Directory kullanarak tek bir çatı altında birleştiren yapıdır. Bu yapıya ihtiyaç duymamızın sebebi her cihazı yetkilendirebilir, sınırlarını çizebilir, gerekli yazılımları uzaktan yükleyebilir, cihazları gruplar halinde ayırabiliriz.

2. Forest & Trees: "Orman ve Ağaçlar"

- Active Directory mimarisindeki "Domain", "Tree" (Ağaç) ve "Forest" (Orman) kavramları hiyerarşik olarak neyi ifade eder? Birbirleriyle olan güven ilişkisi (Trust Relationship) mantığı nedir?

➢ Domain dediğimiz şey o şirkettin belli bir bölümünü oluşturan cihazlar mesela BT Cihazları, Tree ise BT, İK vb. tüm cihazların birleştiği yapı, Forest ise birden fazla Tree nin birleştiği yapıdır. Trust Relationship hangi cihazın hangi cihaza erişebileceğini kontrol eden yapı(yani yetki kontolü) mesela bu yapıda birbirleriyle güven ilişkileri Forest → Tree →Domain şeklindedir.

3. Group Policy Objects (GPO): "Kuralların Gücü"

- Group Policy Object (GPO) nedir? Bir sistem yöneticisi (SysAdmin), tek tek masaları dolaşmak yerine GPO kullanarak ağdaki yüzlerce bilgisayarı ve kullanıcıyı nasıl yönetir/kısıtlar? (Örnek vererek açıklayın).

➢ Group Policy Objects tek seferde tüm cihazlara giden (mesela BT cihazları ,Muhasebe cihazlarına) kural yazabilme işidir. Mesela SysAdmin öncelikle BT kullanıcılarını IT-OU içine koydu ve bir kural yazdı BT kullanıcılarından biri bilgisayarını açtığında bilgisayarın ilk işi DC ye gidip yeni kural varmı diye bakmak eğer kural varsa onu çeker ve uygular.

⚙ FAZ 3: Mühendislik Vizyonu ve Saldırı Sözlüğü (Conclusion)

1. Pass the Ticket (PtT) Saldırısı:

- **Soru:** Bir Kırmızı Takım üyesi olarak, elinizde kullanıcının parolası veya NTLM hash'i olmadan, sadece çalınmış bir Kerberos bileti (TGT/TGS) ile sisteme nasıl sızarsınız? Bu saldırının arka planındaki çalışma mantığı nedir?

➢ Pass the Ticket saldırısında şifreye ihtiyaç yoktur; onun yerine "bilet" dediğimiz geçici bir kimlik doğrulama nesnesi kullanılır (geçici pasaport gibi). Bileti Mimikatz gibi araçlarla hedef sistemin belleğinden çalar, kendi oturumumuza enjekte ederiz ve o biletin sahibi kullanıcıymış gibi davranırız. Bilet geçerliyse Kerberos şifre sormaz, doğrudan erişim verir.

2. AS-REP Roasting Saldırısı:

- **Soru:** Bu saldırı, sistem yöneticisinin yaptığı hangi kritik yapılandırma hatasından (Pre-Auth / Ön Kimlik Doğrulama eksikliği) beslenir? Saldırgan bu hatayı kullanarak domain'deki bir kullanıcının hash'ini sistemi uyandırmadan nasıl çalar?

➢ Kerberos'ta normalde bir kullanıcı TGT istemeden önce ön doğrulama (Pre-Authentication) yapmalıdır. Ama bazı şirketler eski uygulamalarla uyumluluk için "Do not require Kerberos preauthentication" seçeneğini açar; bu seçenek ön doğrulama yapmadan TGT alınmasını sağlar. Saldırgan, bu hesap için KDC'ye AS-REQ gönderir; KDC ön doğrulama beklemediği için doğrudan AS-REP döner. Bu AS-REP içinde kullanıcının şifresinin hash'i ile şifrelenmiş bir bölüm bulunur. Saldırgan bu bölümü John the Ripper veya Hashcat gibi araçlarla offline kırar ve sistemi uyandırmadan şifreyi ele geçirmiş olur.

3. Kerberoasting Saldırısı:

- **Soru:** Active Directory ortamında neden özellikle Servis Hesapları (Service Principal Name - SPN) hedeflenir? Bir saldırganın, geçerli düşük yetkili bir kullanıcıyla içeri girdikten sonra bilet (TGS) talep edip, bu biletin şifresini kendi evindeki bilgisayarda (Offline Cracking) kırmasını sağlayan Kerberos tasarım zafiyeti nedir?

➢ SPN (bir servisin Active Directory'deki kimliği) hedeflenmesinin sebebi, insan eli değmediği için şifresinin nadiren değişmesi, kolay tahmin edilebilir olması ve genelde yüksek yetkilere sahip olmasıdır. Kerberos'un tasarım zafiyeti şudur: KDC, TGS isteyen kullanıcının o servise yetkili olup olmadığını kontrol etmez geçerli bir TGT'si olan herhangi bir düşük yetkili kullanıcı bile istediği SPN için TGS talep edebilir. KDC bu bileti, hedef servis hesabının NTLM hash'i ile şifreleyip gönderir. Saldırgan bu bileti kendi makinesine taşıyıp Offline Brute-Force Attack yöntemiyle GPU üzerinde çok hızlı şekilde kırabilir; bu sırada ne hesap kilitlenir ne de log üretilir.

4. Golden Ticket (Altın Bilet) Saldırısı:

- **Soru:** "Golden Ticket" nedir ve üretmek için neden özellikle Domain Controller üzerindeki **KRBTGT** hesabının hash'ine ihtiyaç duyarız? Bu bilet saldırgana sistemde nasıl bir kalıcılık (Persistence) ve "Sınırsız Erişim" sağlar?

➢ KRBTGT hesabının hash inin elimizde bulunması demek istedğimiz türden TGT bileti üretebiliriz demek çünkü KDC hash değerinin içeriğine bakmaz KRBTGT tarafından imzalanmışmı diye bakar. Bizim elimizdede KRBTGT nin hash olduğu için o bilgi orada olmasa bile oradaymış gibi enjekte edebiliriz. Bu da bize Golden Ticket sahibi yapar buda sınırsız erişim demek.

5. Silver Ticket (Gümüş Bilet) Saldırısı:

- **Soru:** Silver Ticket'ın, Golden Ticket'tan (Altın Bilet) mimari ve yetki kapsamı olarak en büyük farkı nedir? Neden bazen Domain Controller'ı (KRBTGT) hedef almak yerine, sadece spesifik bir servisi (Örn: SQL Sunucusu) hedef alan Gümüş Bilet üretmeyi tercih ederiz?

➢ Golden Ticket ile Silver Ticket arasındaki temel fark şudur: Golden Ticket sahte bir TGT üretir ve KRBTGT hash'i ile imzalandığı için tüm domain'e sınırsız erişim sağlar; Silver Ticket ise sahte bir TGS üretir ve sadece hedef servisin NTLM hash'i ile imzalandığı için yetkisi yalnızca o servisle sınırlıdır. Bu yüzden Golden Ticket'ta saldırgan KDC ile konuşmak zorundadır, Silver Ticket'ta ise TGS zaten elde olduğu için KDC'ye hiçbir sorgu yapılmaz.

➢ Silver Ticket'ı tercih etme sebebimiz daha az gürültü çıkarmasıdır; çünkü doğrudan tek bir servise gidilir ve KDC'ye hiçbir sorgu yapılmaz, dolayısıyla Domain Controller loglarında iz bırakmaz. Ayrıca Domain Controller'ı ele geçirmek yerine sadece hedef servisin sunucusundan hash almak yeterli olduğu için elde edilmesi de daha kolaydır.